Infrastructure and Dependency Management Policy

App: Time on the record (Zoom App)
Owner / security contact: danielbermudez6one9@gmail.com
Last reviewed: 2026-10-17 · **Review cadence:** at least every 12 months

1. Dependencies

1.1 Approved sources

- Runtime and build dependencies come only from the public npm registry, through `package.json`, with exact resolved versions and integrity hashes locked in the committed `package-lock.json`.
- No runtime script, style, or library is loaded from a third-party CDN.
    - The Zoom Apps SDK is served from the app's own origin out of the pinned `@zoom/appssdk` package.
    - The only external resource is the IBM Plex web font from Google Fonts. It is allowed by the CSP as a stylesheet/font only, never script.

1.2 Adding a dependency

Before adding a package, the owner checks that it is:

- actively maintained;
- widely used;
- free of open high/critical advisories (`npm audit` after install);
- not overlapping with something already in the project.

Prefer the platform (Node.js built-ins, browser APIs) over new packages. The current production dependency set is deliberately small:

Package	Purpose
`express`	HTTP server
`cookie-session`	Signed session cookie
`axios`	Token exchange with Zoom
`dotenv`	Load secrets from environment
`@zoom/appssdk`	Zoom Apps SDK

1.3 Monitoring and updating

- `npm audit` runs on every release and at least monthly. Findings are handled under the Vulnerability Management Procedures timelines.
- Routine (non-security) minor and patch updates are applied at least quarterly. Major upgrades are scheduled deliberately and tested in a live Zoom meeting.
- Every dependency change is a commit that includes the updated `package-lock.json` and a passing `npm run security-check`.

1.4 Removal

Unused dependencies are removed when found, and reviewed as part of each quarterly update.

2. Infrastructure

Item	Detail
Runtime	Node.js LTS (≥ 18; currently tested on v24)
Transport	HTTPS only, through Cloudflare, which manages the TLS certificate; HSTS sent on every response
Secrets	`ZOOM_CLIENT_ID`, `ZOOM_CLIENT_SECRET`, `ZOOM_REDIRECT_URI`, `ZOOM_WEBHOOK_SECRET_TOKEN` stored in a `.env` file on the server; never in the repository (`.env` is git-ignored and has never been committed)
Data stores	None persistent. Timer totals are in process memory and lost on restart. No database.
Access	The Zoom Marketplace and GitHub accounts are used only by the owner.
Source code	GitHub repository (public; owner-only write access). It contains no secrets: `.env` is git-ignored, and secrets exist only on the server.

2.1 Secret rotation

The Zoom client secret and webhook secret token are rotated:

- immediately if exposure is suspected (see the Incident Management and Response Policy);
- otherwise at least every 12 months.

Rotation means regenerating the values in the Zoom Marketplace dashboard, updating the server's `.env` file, and restarting the server.

2.2 Runtime patching

- The Node.js runtime stays on a supported LTS release. Security releases are applied within the vulnerability-management timelines.

2.3 Logging

- Server logs record errors and deauthorization events (account and user IDs only).
- Logs never contain OAuth codes, tokens, client secrets, or webhook secrets.
- Logs are written to the server console only. They are not saved to files or exported elsewhere.
